Prepared by: Rubaia Morshed

Web Application Penetration Testing: SQL Injection Exploitation via Burp Suite

Conducted SQL injection testing, successfully exploiting vulnerabilities to retrieve hidden data and bypass authentication mechanisms.

Lab1: SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

Question : In this lab a SQL injection vulnerability in the product category filter. When the user selects a category, the application carries out a SQL query like the following:

```
SELECT * FROM products WHERE category = 'Gifts' AND released = 1
```

To solve the lab, perform a SQL injection attack that causes the application to display one or more unreleased products.

Solve:

Step 1 : Navigated to the website

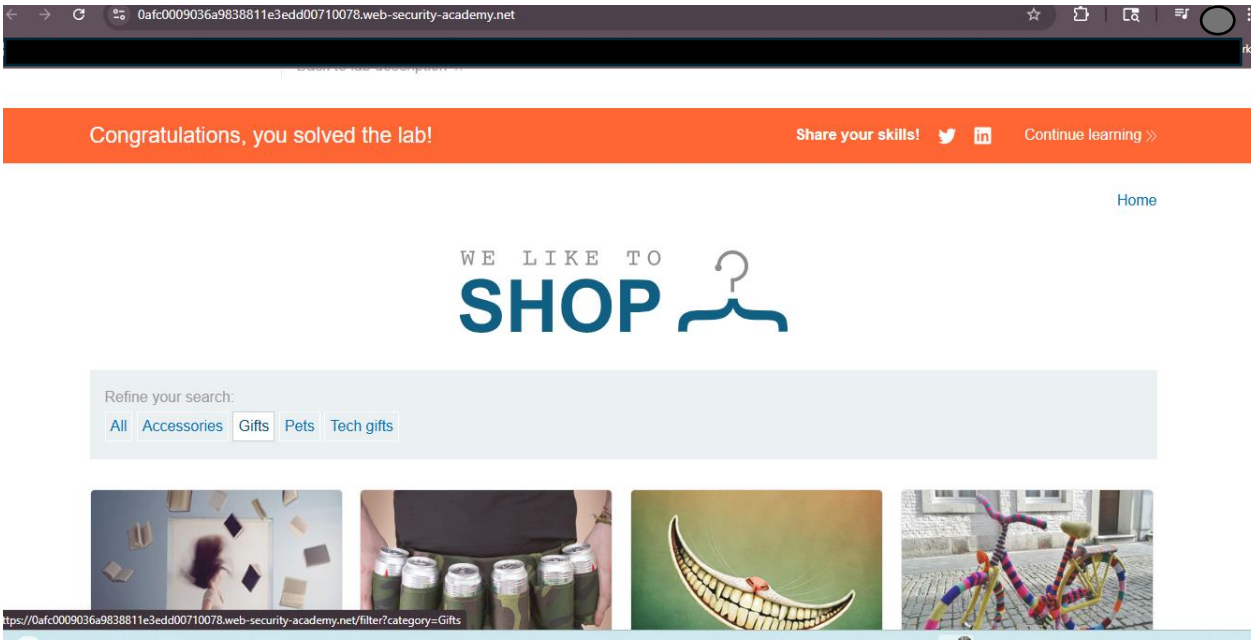

Figure 1:Navigate to the website

Step 2 : Clicked the option Gifts (Arrow marked) in the filter area of the Website .

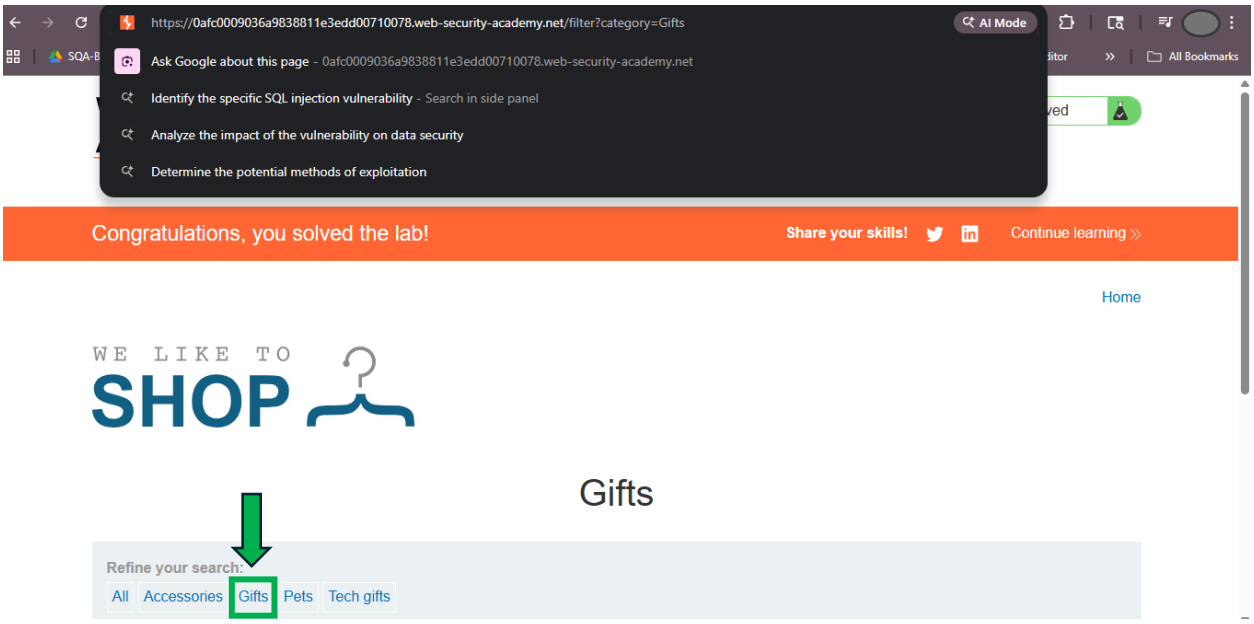

Figure 2:Selected Gifts Option

Step 3 : In the browser URL modified the category parameter, giving it the value '+OR+1=1--

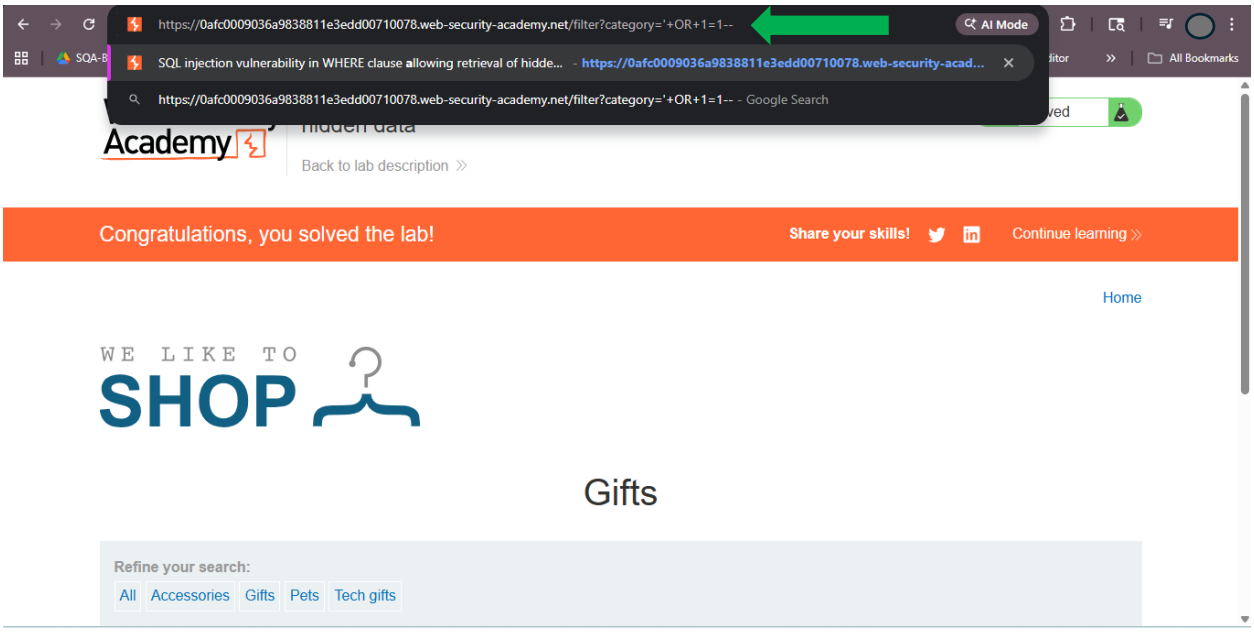

Figure 3:Injecting Value in Category parameter to reveal hidden items

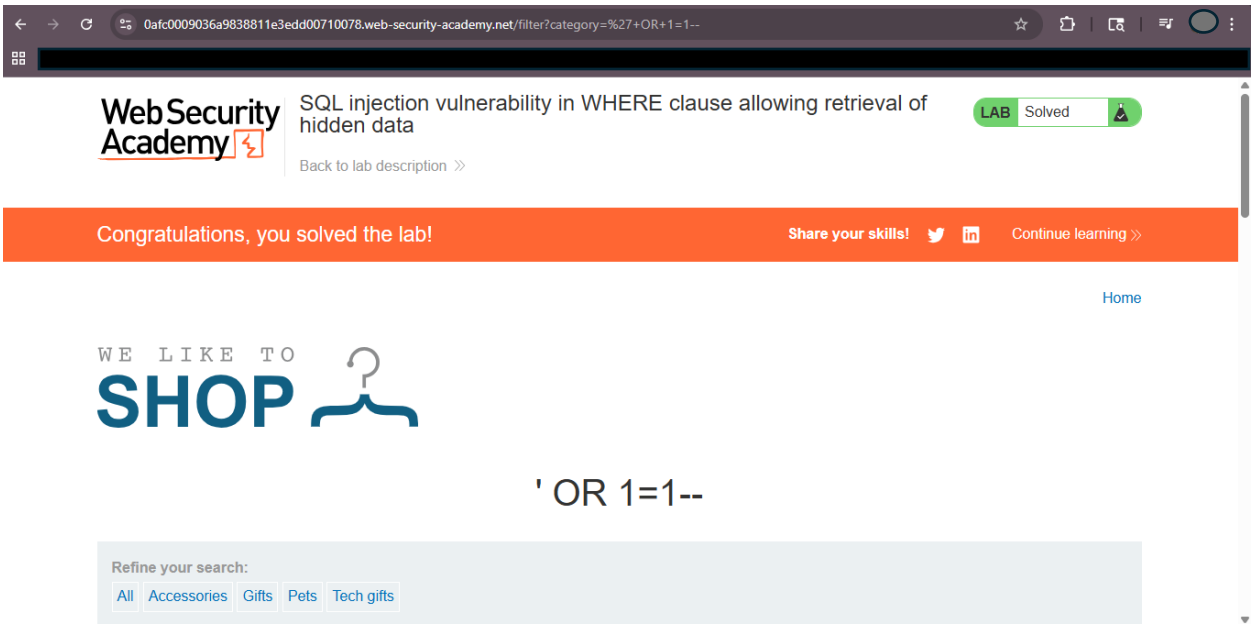

Figure 4:Hidden Items are visible

Now Hidden items are shown which are unreleased products.

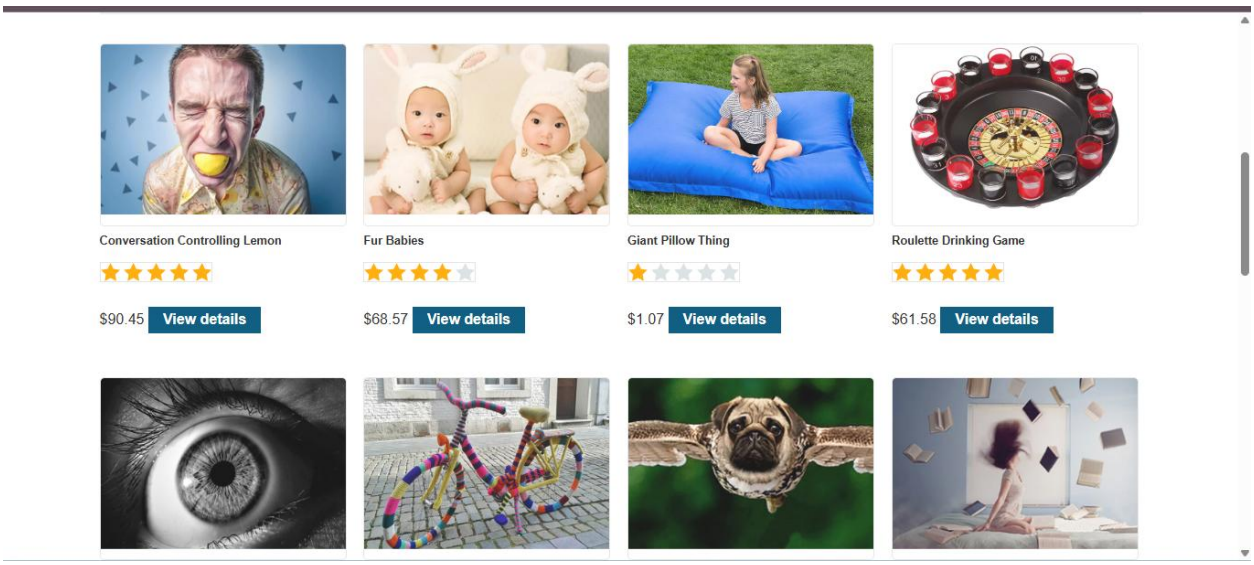

Figure 5:Hidden Items are visible 2

Lab 2: Exploited SQL injection to bypass authentication and gain unauthorized access.

Question: This lab contains a SQL injection vulnerability in the login function.

To solve the lab, perform a SQL injection attack that logs in to the application as the `administrator` user.

Solve : Navigate to the My Account web page and clicked username field (Green arrow marked) in login. Modified the username parameter, giving it the value: **"**administrator'-- **"** .In Password field (Green arrow marked), press any key to proceed with administrator login. I input **"**1234**"** and was able to bypass and logged in as administrator.

Note: Authentication was bypassed by injecting a valid username, allowing access without proper password validation. As a result, any input was accepted as a password.

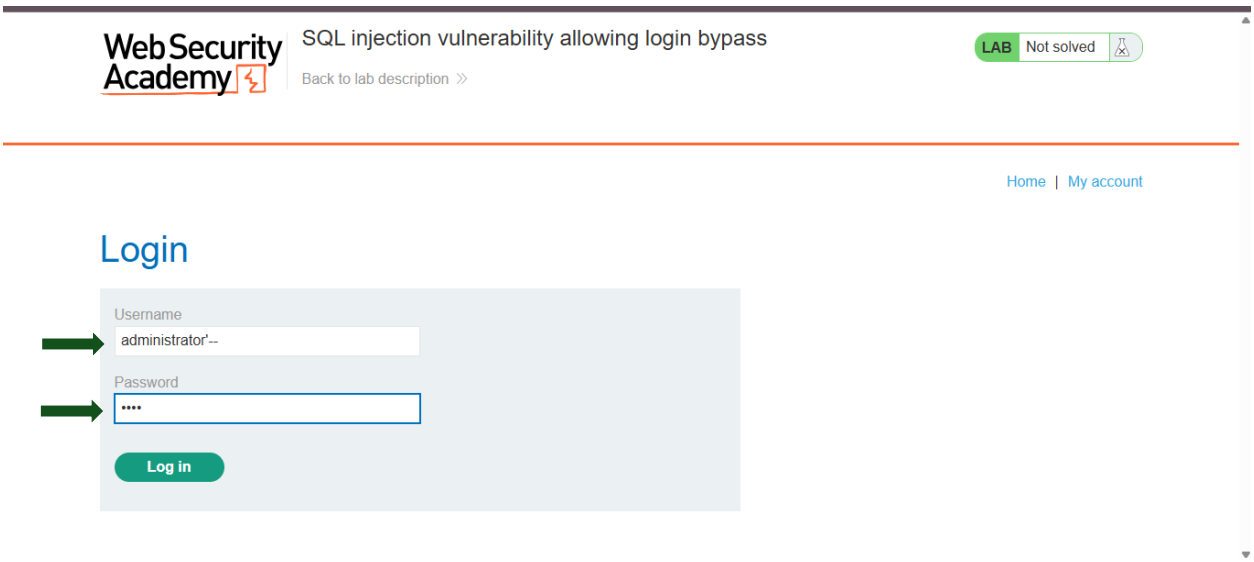

Figure 6:Injecting username to login as administrator

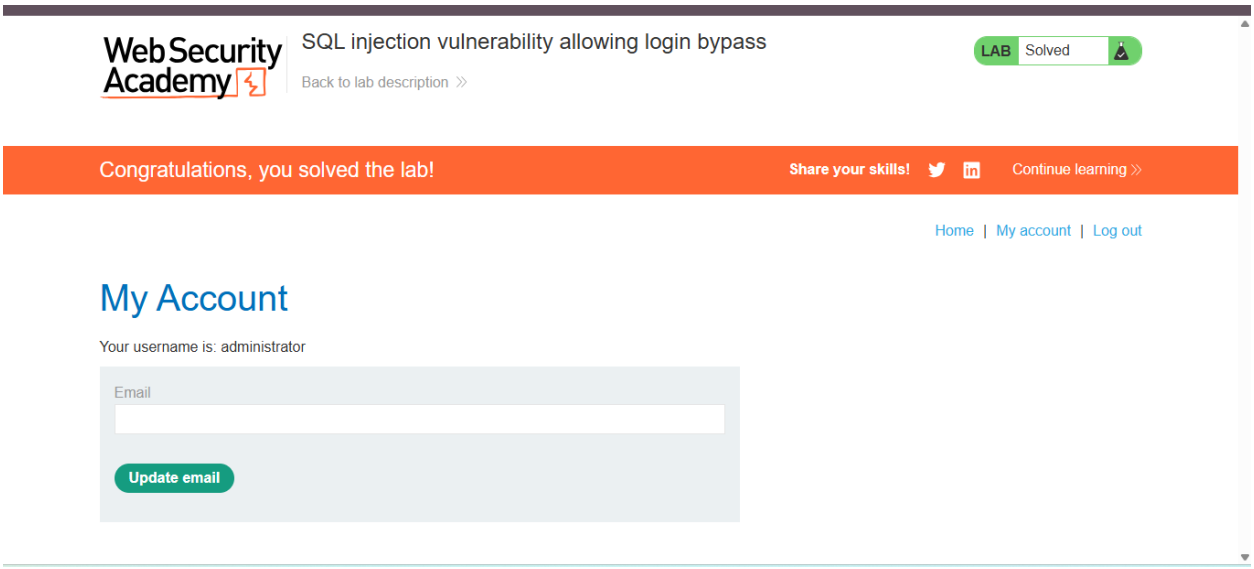

Figure 7: Successfully bypass authentication